

Clase 6

ISO/IEC 27032 – Cybersecurity Guidelines

La norma **ISO/IEC 27032:2012** establece lineamientos para la protección del **cibespacio**, comprendiendo redes interconectadas, usuarios, servicios y mecanismos de **confianza digital**.

Su objetivo principal es **definir un marco de cooperación entre múltiples actores** —usuarios, proveedores, gobiernos, y equipos de respuesta a incidentes (CERTs/CSIRTs)— con el fin de reducir los riesgos derivados de la interconexión global.

Objetivo

Promover una visión integral de la ciberseguridad que trascienda la seguridad tradicional de la información, abarcando la protección de activos digitales en entornos distribuidos y colaborativos.

Alcance de la Ciberseguridad

La ciberseguridad, según la ISO/IEC 27032, extiende la gestión de la seguridad de la información hacia un **entorno interconectado**, abarcando:

- **Amenazas del cibespacio:** malware, phishing, ataques de red, entre otros.
- **Protección de información compartida** entre usuarios, organizaciones y plataformas.
- **Identidad digital y confianza**, mediante autenticación, gestión de identidades y privacidad.
- **Gestión de incidentes y cooperación internacional**, fortaleciendo la coordinación con CERT/CSIRT y la respuesta colaborativa.

Principios Rectores

- **Colaboración intersectorial:** cooperación entre gobiernos, sector privado, academia y usuarios.
- **Gestión de identidad y confianza:** refuerzo de autenticación, integridad y no repudio.

- **Protección de infraestructuras críticas:** adopción de un enfoque preventivo frente a amenazas emergentes.
- **Conciencia y capacitación:** fomento de una cultura cibersegura en todos los niveles organizacionales.
- **Resiliencia del ciberespacio:** detección temprana, respuesta coordinada y recuperación ante incidentes.

Frameworks y Regulaciones en Ciberseguridad

Cybersecurity Maturity Model Certification (CMMC)

El **CMMC** es un modelo de madurez en ciberseguridad desarrollado por el **Departamento de Defensa de Estados Unidos (DoD)** para evaluar, estandarizar y certificar el nivel de seguridad de los contratistas que manejan información del gobierno federal.

Objetivo

Garantizar que las organizaciones dentro de la **Defense Industrial Base (DIB)** protejan de forma adecuada la información sensible, en especial:

- **FCI (Federal Contract Information)**
- **CUI (Controlled Unclassified Information)**

Modelo de Madurez (niveles y controles)

Nivel	Enfoque	Controles / Referencias
1 – Foundational	Prácticas básicas de higiene cibernética. Protege FCI.	17 prácticas (basadas en FAR 52.204-21)
2 – Advanced	Implementación formal de políticas y procesos. Protege CUI.	110 controles de NIST SP 800-171 Rev.2
3 – Expert	Gestión avanzada de amenazas persistentes (APT).	Basado en NIST SP 800-172 + prácticas DoD

Cada nivel incluye los requisitos del anterior (modelo incremental).

Características del modelo

- Controles verificables mediante auditorías externas realizadas por **C3PAOs (Third Party Assessment Organizations)**.

- Evaluación de **madurez organizacional**, no solo controles técnicos.
- Se analizan tres dimensiones principales:
 1. Políticas y procedimientos.
 2. Capacidades técnicas y gestión de riesgos.
 3. Procesos de mejora continua.

Línea temporal del CMMC

Año	Evento	Descripción
2019	Inicio del programa CMMC	Lanzamiento oficial del proyecto DoD.
2020 (enero)	Publicación CMMC v1.0	Primera versión con 5 niveles de madurez.
2021 (noviembre)	CMMC v2.0	Reducción de niveles a 3 y alineación con NIST SP 800-171.
2022–2024	Transición y armonización	Implementación del programa de auditorías C3PAO y guías oficiales CISA/DoD.
2025 (actual)	Aplicación obligatoria	CMMC v2.0 se integra formalmente a los contratos del DoD.

Implementación y beneficios

- Requisito obligatorio para contratistas del DoD.
- Escalable a sectores críticos (energía, infraestructura, manufactura).
- Integra marcos como **NIST CSF**, **CIS Controls** e **ISO/IEC 27001**.

Beneficios: estandarización en la cadena de suministro, madurez progresiva y fortalecimiento de la confianza industrial.

HIPAA – Health Insurance Portability & Accountability Act

La **HIPAA** (1996) es una ley federal de EE.UU. que regula la **privacidad**, **seguridad y disponibilidad** de la información médica.

Su propósito es asegurar que los datos de salud sean **confidenciales, íntegros y disponibles**.

Ámbito de aplicación

- Hospitales, clínicas y laboratorios.
- Compañías de seguros y prestadores de salud.
- Proveedores tecnológicos que procesen datos médicos.

Principales Reglas

Regla	Propósito	Enfoque técnico
Privacy Rule (2003)	Derechos del paciente sobre su información médica.	Políticas de acceso, uso y divulgación del PHI.
Security Rule (2005)	Salvaguardas administrativas, físicas y técnicas.	Cifrado, autenticación, control de acceso, auditorías.
Breach Notification Rule (2009)	Reporte obligatorio de incidentes y filtraciones.	Notificación a usuarios y autoridades ≤ 60 días.
Omnibus Rule (2013)	Extiende responsabilidades a proveedores tecnológicos.	Integración con cloud y software médico.

Salvaguardas técnicas

- Control de acceso y autenticación.
- Auditoría y trazabilidad.
- Integridad de datos.
- Cifrado de datos en tránsito (TLS, VPN).

Implementación y certificación

- Evaluaciones periódicas de riesgo (**Risk Assessment**).
- Políticas de seguridad documentadas y capacitación de personal.
- Acuerdos de confidencialidad (**Business Associate Agreements**).

Relación con la PKI

- Uso de certificados digitales X.509.
- Integración con marcos como **NIST CSF**, **ISO/IEC 27001** y **HITRUST CSF**.

PCI DSS – Payment Card Industry Data Security Standard

El **PCI DSS** surge en 2004, cuando Visa, MasterCard, American Express, Discover y JCB unificaron sus estándares de seguridad en un marco común.

En 2006 se creó el **Payment Card Industry Security Standards Council (PCI SSC)**, responsable del mantenimiento del estándar.

Evolución

- **v1.0 (2004)**: primera versión.
- **v2.0 (2010)**: mejoras de evaluación.
- **v3.2 (2016)**: refuerzo en autenticación y cifrado.
- **v4.0 (2022)**: enfoque en seguridad continua y gestión basada en riesgo.

Objetivos fundamentales

1. Construir y mantener una red segura.
2. Proteger los datos del titular de la tarjeta.
3. Mantener un programa de gestión de vulnerabilidades.
4. Implementar controles de acceso.
5. Monitorear y probar redes regularmente.
6. Mantener una política de seguridad de la información.

Requisitos principales

- Firewall y eliminación de contraseñas predeterminadas.
- Cifrado de datos y transmisión segura (TLS $\geq$ 1.2).
- Antivirus actualizado y desarrollo seguro.
- Autenticación multifactor y control de privilegios.
- Escaneos y pentesting regulares.

Validación y cumplimiento

Dependiendo del volumen de transacciones:

- **SAQ (Self-Assessment Questionnaire)** o auditoría por **QSA (Qualified Security Assessor)**.
- Certificación anual y escaneo trimestral de vulnerabilidades.

El incumplimiento puede implicar **multas, suspensión de contratos y pérdida de habilitación comercial**.

Reglamento Europeo de Ciberseguridad (UE 2019/881 y UE 2024/2847)

El **Cybersecurity Act** (UE 2019/881) establece un marco común de **certificación europea** para productos, servicios y procesos TIC, bajo la autoridad de **ENISA**.

La actualización **UE 2024/2847** amplía el alcance e introduce requisitos para productos con **componentes digitales**, incluyendo IoT, software embebido y hardware inteligente.

Certificación europea

Tres niveles de garantía:

1. **Básico**: controles mínimos, autoevaluación.
2. **Sustancial**: auditorías independientes y gestión de riesgos.
3. **Alto**: validación estricta y pruebas continuas.

Aplica a dispositivos conectados, plataformas cloud y proveedores de servicios gestionados.

Impacto e implicancias

- Cumplimiento obligatorio para comercializar en la UE.
- Enfoque "**security by design**" en desarrollo y producción.
- Promoción de interoperabilidad y confianza digital.
- Nuevas oportunidades laborales en **auditoría y certificación**.

Normas complementarias

- **NIS2 (UE 2022/2555)**: resiliencia y gestión de incidentes.
- **Cyber Resilience Act (CRA, 2024)**: seguridad integrada desde el diseño.
- **CER Directive (UE 2022/2557)**: resiliencia de infraestructuras críticas.

Política de Seguridad de la Información

Políticas Nacionales y Universitarias

- **Modelo de Política de Seguridad** para organismos públicos (Jefatura de Gabinete).

- **Decisión Administrativa 641/2021:** requisitos mínimos de seguridad de la información.
- **Resolución CIN 1669/22:** política de seguridad para universidades públicas.

Aspectos a incluir

- **Protección de datos personales:** cumplimiento del **RGPD europeo**.
 - **Privacidad y derecho al olvido:** transparencia en recolección y gestión de datos.
 - **Responsabilidad del CPO (Chief Privacy Officer):** supervisión del cumplimiento normativo.
-

Estructura Organizacional en Seguridad y Ciberseguridad

Organización y roles principales

- **Comité de Ciberseguridad:** define estrategias y políticas globales.
- **CISO (Chief Information Security Officer):** responsable de la estrategia, gestión de riesgos y cumplimiento.
- **CPO (Chief Privacy Officer):** encargado de la protección de datos personales.
- Coordinación entre áreas: **SOC, CSIRT, IT y Legal**.

SOC – Security Operations Center

- Monitoreo en tiempo real de la infraestructura tecnológica.
- Uso de herramientas como **SIEM, IDS/IPS y EDR**.
- Detección y respuesta inicial ante incidentes.
- Generación de alertas y reportes continuos.

CSIRT – Computer Security Incident Response Team

- Gestión completa del ciclo de incidentes (detección, contención, erradicación y recuperación).
- Coordinación con organismos externos y reguladores.

- Análisis forense y elaboración de planes de respuesta y continuidad.